



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



New Rokarolla Android Malware Steals PINs, SMS Codes, and Crypto Wallet Funds

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | New Rokarolla Android Malware Steals PINs, SMS Codes, and Crypto Wallet Funds - Malware Analysis Report

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

1. Executive Summary

Lost Boys Cyber assesses Rokarolla as a high-impact Android banking trojan focused on financial account takeover, SMS one-time-password interception, and cryptocurrency payment theft. Public reporting from Zimperium zLabs, amplified by The Hacker News on 2026-06-16, describes a malware family distributed through malicious websites impersonating popular applications such as TikTok, Google Chrome, and Google Play Protect. Once installed, Rokarolla abuses Android Accessibility Services and role/permission prompts to gain broad control over the victim device.

The family is notable for operational breadth rather than a single novel exploit. Zimperium reports 217 targeted banking and cryptocurrency applications and 137 remote commands, including overlay injection, lock-screen credential capture, SMS theft and sending, call blocking, notification reading, keylogging, screen/UI logging, clipboard replacement, Google Play Protect disablement, and C2 failover. This gives the operator enough access to defeat common consumer protection assumptions: a victim may still have MFA enabled, banking fraud calls active, and Play Protect present, yet Rokarolla can target all three controls after social-engineering the initial install and permissions.

Finding	Defensive significance	Confidence
Rokarolla targets Android users through fake-app and fake-security-app delivery.	Mobile device policy should treat sideloaded APKs and Accessibility prompts as high-priority financial-fraud indicators.	High
The malware uses HTML overlays for banking and crypto credential phishing.	Brand-login telemetry alone is insufficient; organizations need mobile threat defense, device posture, and anomalous transaction controls.	High
SMS handler and call-screening abuse enables OTP theft and fraud-call suppression.	SMS OTP should not be treated as a strong standalone control for high-risk transactions.	High
Clipboard replacement enables crypto-payment redirection.	Wallet users and exchange operators should hunt for clipboard manipulation and unexplained destination-address substitution.	Medium-High
Public IOCs include 40 APK SHA-256 hashes and several domains.	IOC blocking is useful but incomplete because the family supports fallback and dynamic C2 updates.	High

Analyst bottom line: Rokarolla should be handled as a full-device compromise event, not as isolated credential phishing. If a user's Android device is suspected infected, response should include account lockout/recovery, SIM/SMS/phone-call review, cryptocurrency-transaction review, device wipe/re-enrollment, and removal of the device from trusted-device lists.

2. Sample Metadata

No Rokarolla APK sample was detonated directly by Lost Boys Cyber for this intake. The metadata below is source-backed from Zimperium's public analysis and IOC repository and should be treated as a research/intelligence report rather than an original reverse-engineering case file.

Field	Value
Report ID	LBC-MA-2026-020
Malware family	Rokarolla
Malware class	Android banking trojan / mobile financial malware
Platform	Android

First-party research source	Zimperium zLabs
Intake source	The Hacker News
Published date	2026-06-16
Distribution	Malicious websites masquerading as popular apps / fake security tooling
Primary abuse surface	Accessibility Services, overlay windows, SMS/Call default-role prompts, notification access, clipboard access
Targeting scope reported by source	217 banking and cryptocurrency applications
Remote command count reported by source	137 commands
Public sample indicators	40 APK SHA-256 hashes in Zimperium IOC repository
Attribution	No named actor attribution in public reporting
Lost Boys Cyber confidence	High on capabilities and IOCs; medium on victimology and campaign scale

3. Source Review & Confidence

Source	Type	What it contributes	Reliability assessment
Zimperium zLabs, “Rokarolla: Android Banker with Complete Device Takeover Capabilities”	Primary vendor research	Technical analysis, command behavior, delivery path, C2 behavior, permission abuse, overlay workflow, IOC repository link	High. Zimperium provides mobile malware research and public IOCs, but full sample corpus and lab artifacts were not independently reproduced by LBC.
Zimperium/IOC GitHub repository, `2026-06-Rokarolla`	IOC repository	40 APK SHA-256 hashes and a 137-command reference table	High for indicator transcription; medium for completeness because campaign infrastructure can rotate.
The Hacker News, “New Rokarolla Android Malware Steals PINs, SMS Codes, and Crypto Wallet Funds”	Secondary security reporting	Concise external confirmation of capabilities, delivery, and defensive implications	Medium-High. Useful corroboration but based on Zimperium’s primary research.
Utopia Tech repost/summary	Secondary aggregation	High-level summary of the THN/Zimperium findings	Medium. Not used as a primary technical authority.

Evidence boundaries and assumptions:

- Lost Boys Cyber did not receive a customer device image, APK sample, packet capture, or sandbox execution trace for this task.
- Static/code/dynamic sections therefore distinguish source-observed facts from LBC analytical interpretation.
- Detection content is written for enterprise telemetry patterns and should be tuned to each organization’s MDM, mobile-threat-defense, DNS/proxy, EDR, SIEM, and banking-fraud datasets.

- Android malware can mutate package names, certificates, command strings, C2 domains, and overlay templates quickly; the IOCs in this report are starting points, not complete coverage.

4. Initial Triage and Delivery Assessment

Rokarolla's infection chain begins with social engineering rather than an Android platform CVE. Public reporting indicates victims are directed to malicious websites that present trojanized applications as legitimate software. Zimperium specifically identified a malicious distribution site using `hxps://infocontabilidades[.]it[.]com/` and examples impersonating TikTok, Google Chrome, and Google Play Protect. The dropper then masquerades as a legitimate security or platform component to persuade the user to approve additional installation and accessibility permissions.

Stage	Observed or assessed behavior	Control implication
Lure	Fake popular-app or fake-security-app website.	Block sideloading where possible; monitor mobile browsers and DNS for known distribution domains.
Dropper	Initial app presents itself as Google Play Protect or a similarly trusted component.	User education must stress that Google Play Protect is not installed through random web prompts.
Permission escalation	Malware requests Accessibility Services, SMS access, notification access, call/SMS default roles, Do Not Disturb, modify-system-settings, and all-files access depending on command path.	Treat new Accessibility grants to unapproved apps as a critical alert.
Payload operation	C2 registers device telemetry and commands the implant.	Mobile telemetry should correlate suspicious permissions with outbound HTTPS to rare domains.
Monetization	Banking/crypto overlays, OTP theft, call suppression, clipboard swap, and remote UI control enable account takeover and transaction manipulation.	Account recovery and fraud monitoring must begin immediately after suspected infection.

Delivery risk is highest for unmanaged Android devices, bring-your-own-device programs with weak sideloading controls, cryptocurrency users, and banking customers who rely on SMS OTP. Enterprise risk includes compromise of executives, finance personnel, and staff who access corporate banking, crypto treasury, password managers, messaging apps, or customer-support fraud workflows from personal or lightly managed Android devices.

5. Static Analysis

The public IOC set contains 40 SHA-256 APK hashes associated with Rokarolla. The report does not expose full APK manifests, package names for every sample, signing certificates, or a canonical unpacked configuration for each hash. However, source reporting and the command reference indicate the samples include strings, components, and permission requests consistent with Android banker tradecraft.

Static characteristics expected for Rokarolla-family samples:

Static feature	Source-backed observation or analytical expectation	Detection value
APK format	Android application packages; initial dropper plus secondary payload behavior described.	Hash matching and mobile app inventory checks.
Masquerade labels	Fake Google Play Protect / popular app	MDM inventory can detect suspicious app

	branding.	names not signed by expected vendors.
Accessibility abuse	Core workflow depends on Accessibility Services for UI inspection, clicks, overlays, and screen capture.	High-signal when granted to newly installed, non-approved apps.
SMS/call roles	Commands request default SMS handler and call-screening capabilities.	High-signal for a non-communications app.
Overlay capability	HTML login pages and Android lock-screen overlays.	Behavioral detection through overlay-window permission, WebView use, and monitored package triggers.
Local storage	Zimperium describes fake HTML payloads stored in a local SQLite database.	Forensic recovery can look for monitored-app tables, cached HTML, and C2 URL mappings.
C2 failover	Multiple fallback domains and command-driven C2 updates.	Domain-only blocking is fragile; hunt for update-config behavior.

Representative public APK SHA-256 indicators:

#	SHA-256
1	890ecea4ebe4fea692ad36adf02abeb37c181cb7bdb6122cd52d9aaaf e7d6cf3
2	7aa389f25997610a96f014977eecd6d69142bdc63841e0d84976e3e 621831303
3	4e2cbefc6bdbfdb6e885057ce47d460e3d3355a5e97db51b22e9c5a1 4e14302b
4	1ba364113c4cec5542d1b2c76d7c163a66bdf90bc373256d5178f88 0f9742960
5	d7d960ef10b08c472ad397b6fd9e9481338b2077c7c2f44d3dc2c65 b19345ae0
6	57307ee8a3cda10730eacecaf789fab6f8771f9d29397e07c31a6bd45 51bba10
7	3fae7ede2ef9c809b54504c3d78e5111d7fad0b522c707b8f6ff21015 af79251
8	fe41e6c1725f63582f022a17abe098e49338a78118a00ca87785b2fa 0cf3dadf
9	be8573971b85fda81a2fac27adb7a3a9b2cf7e1d9bdf713361a72532 4d378d34
10	5139253b1f30b34ab3aa888aba175866fa1f82728ab07b999c24b49 b191c3f68
11	43888be8debbbd74012484d4e4f9a1c70c2ff3970e0bf499c9aebba9 776930a1
12	a5e6763b09553691c8b42deefb725fa3b8c133a03a34cea87740b1f1

	3d08bac3
13	1d3270a9141f8f16047799f1132633d72fd421b6c8f1878b5ef04ced6add4db8
14	62aef76c2d1897203649844b45317d9e1723819479a2b88ca4b3290ca9f4c9f0
15	48a3db92fac1ba9c218253576e09f42faabeaf48cf80663cf32e06b0a66e983d
16	726095e56c693977b7796dc7cead2e2a49551d77d3f442aaa28997615ba07e99
17	c3cfe522d2da15b033f65eb5377bf9e99be598dc4c21729e6f168dbc8f19540b
18	3e25c28c5e93376683e841b7ad60f9383bb3bf831284a93a4aae798fc769d767
19	8d65e4df0ad369f491698437413afd1bd55fff309860f9cdecc778c9ac062282
20	c08cd3f78c0edcccd6b1a694284b6ed4a9e0422f469e07c702c4a8d1f6c186f4
21	696ef29f77a91aa91279c83088a07ab137d5049dc096ef862a35f9d890a552b3
22	97e76acebea510c8641183866be4392601314b20e73c7ba8cf1f3ee2de6080fd
23	8ddbcebe1014a645855986e85b2c54ee167baf1e9a0d74179faf81a5ee6878f4
24	1e4ed7e40608750cd0bfe96f5ed493a022b58ec54da2345336c522f7c78197af
25	c505353a6c58a21cb7b0343202e8629bee2f121f01c21dd8e0b61b7c55b77495
26	aec2a36e8d68b23444348a7cec2d6ec287cb8810d1e190e04743645426ababb1
27	f49be77b95cabd28d2dfe91786863576f6bd3f43a9d6de67a5b5851afe3aff9a
28	e76cbdf420540a18e2ddea02938acf3c4b4139f3511d314dca9781afe1e439bb
29	c3e324106803df27f5b6e0d49d2daf02d4cde396af4401f1ad29d78198e370b6
30	ed036356fa2d3490d3ddb5ee7ae98bab80b505938f0199d9b10f12266f345896
31	5d0c5d8da8202f512339457ae00ed2d9b9c930cefc63fa5a28a049aba4127ab7

32	9a8ec3b21fdb4167f8fdd46f4d38b9a99ff2d3515ee70215438a1360c1474221
33	d6403ec82659eb62424bb1033615a8df27635080d02e438a4ee7e2334b1155f7
34	c734a665f04eb9ab17047e65940fc35bad0221d59c2fc4fd0d170f2181514034
35	e134cffcbe1fa8a861fd1f9a506f10ca5ff56cd5082360ef13d204676792e8bc
36	f0c18f045e3bb0193ef1169f5fa1abff7aa47e9a23da35cf67bbb9548a5e32c0
37	f8cb375a4129358ad5881c29a6921fc1e5773028c0b31da83298f606118b185a
38	3c304a1ac73590aaf94b62711a5f2fd0cbb863dab13aef6ec1eb156f4a7bd5b9
39	2eb80e5519fc6defcec8cc30a5cf4f75ee5ec8d2435759bb77c19826f1e20efb
40	1f4c70cb317ffd25adc828fbac3bb8f07739e23111f7b7905926489fe35f8973

6. Code Analysis

The public command reference exposes a broad operator interface. The command set indicates Rokarolla is not a simple overlay phisher; it is a remote-control banker with workflows for permission acquisition, device-state manipulation, fraud enablement, UI automation, and resilient C2.

Capability cluster	Representative commands	Analyst interpretation
Device registration and telemetry	`registration_update`, `btn_permission_list`, `update_slots`, `set_slots`	Registers device characteristics, permissions, SIM details, and status so the operator can choose next actions.
Permission and role escalation	`write_setting`, `allowmodify`, `permissiondnd`, `notificationp`, `smsclient`, `callclient`, `permission_all_files`	Guides or automates the victim through dangerous Android permission and role grants.
Overlay and lock capture	`request_pin`, `request_pattern`, `request_password`, `showpinlockoverlay`, `showpatternlockoverlay`, `startoverlay16`, `liveoverlay16`, `show_loading_overlay`	Captures device lock credentials and hides malicious background activity behind deceptive UI.
SMS and call abuse	`change_sms`, `change_sms_auto`, `send_sms`, `get_last_sms`, `disabe_calls`, `calls_block`, `enable_calls`, `sms_overlay_16`, `call_overlay_16`	Enables OTP interception, fraud-message sending, and suppression of verification/fraud calls.
Screen and UI theft	`start_keylogger`, `stop_keylogger`, `startuilogger`, `start_uilogger_loop`, `textextract`, `get_contact`, `loading_screenshot`, `start_vnc`,	Captures keystrokes, active UI text, WhatsApp/contact context, and screenshot-like screen data.

	`stop_vnc`	
Remote interaction	`tap`, `longclick`, `swipe`, `btn_back`, `btn_home`, `btn_recents`, `btn_notifications`, `btn_settings`, `clicktext`, `clickdesc`	Gives the operator automation primitives comparable to remote hands on the device.
Anti-intervention and stealth	`disable_google_play`, `disable_red_alert_for_default`, `hide_app`, `notification_clian`, `disable_sounds_and_vibrations`, `distrub_mode_enabled`, `brightness`	Reduces user warnings, suppresses audio/visual cues, and attempts to hide or preserve control.
Banking/crypto injection	`reset_app_list`, `set_status_packet`, `set_url_packet`, `inject_block`, `inject_unlock`, `open_url`, `close_url`, `copyclipboard`	Maintains monitored target-app state, fetches fake HTML pages, and replaces clipboard data used for crypto payments.
C2 resilience	`update_config_domen`, `update_config_injects`, `update_prefix`, `update_time`	Allows dynamic domain/config changes and scheduled operation.

The command naming contains misspellings such as `disabe\_calls`, `distrub\_mode`, `notification\_clian`, and `start\_keylogger`. Those strings may be useful in static rules, but defenders should not overfit to spelling artifacts because the operator can rename commands in future builds.

Key code-level behaviors described by Zimperium include:

- Initial HTTPS beaconing with device telemetry such as manufacturer, model, Android version, SDK level, security patch, locale, timezone, screen dimensions, battery, RAM, and storage.
- Generation or use of a unique `botId` for victim tracking.
- Retrieval of a monitored-application target list from a `monitored\_app\_full` endpoint.
- Transmission of installed-application inventory through `get\_html\_mapping` and `save\_apps` interactions.
- Local SQLite storage of fake HTML overlay pages for active target packages.
- Accessibility-driven UI-tree parsing and coordinate mapping for automated clicks, screen content extraction, and overlay timing.
- Screenshot capture through Accessibility-derived methods rather than user-visible MediaProjection prompts.

7. Dynamic Analysis

Public dynamic observations show a repeatable execution model that defenders can convert into telemetry correlation. The malware does not need root access to be operationally dangerous; it chains user-approved Android features into a high-control banker workflow.

Dynamic phase	Expected telemetry	Risk
Installation	Unknown APK installed from browser/file manager; app label mimics Google Play Protect, TikTok, Chrome, or another trusted app.	User believes installation is legitimate.
Permission prompting	Accessibility Service enablement, notification access prompt, SMS/call role request, modify-system-settings prompt, Do Not Disturb prompt.	Malware obtains control primitives for stealth, capture, and OTP theft.
Device registration	HTTPS POST containing device model, OS, locale, timezone, screen, battery,	C2 obtains victim inventory and status.

	storage, and generated bot identifier.	
Target selection	Installed-app list sent to server; server returns monitored financial app list and active overlay configuration.	Operator determines which banking/crypto brands to phish.
Overlay download	Fake HTML pages retrieved and stored locally.	Credential collection can occur offline/near-real-time when target app is opened.
Runtime fraud	Lock-screen overlay, keylogging, screen/UI logging, SMS read/send, call blocking, clipboard replacement, Google Play Protect disablement.	Account takeover and transaction manipulation become feasible.
C2 failover	Dynamic update of C2 domains and command/config values.	Domain takedowns alone may not terminate active infections.

A suspected infected device should be isolated from enterprise access immediately. Because Rokarolla can read notifications, SMS, and on-screen content, assume that passwords, banking credentials, crypto wallet addresses, MFA codes, recovery codes displayed on screen, and messaging contacts visible during infection may have been exposed.

8. Process Tree and Execution Chain

Android malware does not produce a traditional Windows-style process tree in most enterprise telemetry. The relevant execution chain is application/component and permission-state driven:

```
Victim browser / messaging app
-> malicious website presenting fake popular/security app
-> APK download and user-driven install
-> dropper masquerading as Google Play Protect or popular app
-> second-stage Rokarolla payload
-> Accessibility Service enabled by victim
-> notification/SMS/call/modify-settings roles requested
-> HTTPS registration beacon with device telemetry
-> C2 returns commands, monitored app list, C2 fallback data
-> local database stores fake HTML overlays for active target apps
-> victim opens real banking/crypto app
-> Rokarolla displays fake overlay above legitimate app
-> credentials/card data/lock PIN/SMS OTP/UI text exfiltrated
-> optional call blocking, clipboard replacement, screen capture, remote taps/swipes
```

Execution-chain pivots for responders:

Pivot	What to collect
Install source	Browser downloads, package installer logs, MDM install events, file-manager activity.
App identity	Package name, app label, signing certificate, install time, granted permissions, Accessibility Service name.
Role changes	Default SMS app history, call-screening role history, notification-listener access changes.
Network	DNS/proxy logs for listed domains and rare newly registered `.cfd`, `.info`, and `.it.com` subdomains around install time.
Account activity	Banking/crypto login records, OTP use, rejected/blocked fraud calls, changed trusted devices, wallet transfer history.

9. Persistence and System Modification

Rokarolla's persistence is primarily permission and role persistence, not kernel-level persistence. The malware remains effective because dangerous Android permissions can remain active after initial social engineering.

Persistence or modification	Description	Response action
Accessibility Service grant	Enables UI parsing, overlay timing, automated taps, screen capture, and privilege-guided workflows.	Remove grant, uninstall app, and factory reset if account takeover risk exists.
Default SMS handler	Enables SMS read/send and OTP interception.	Restore legitimate SMS app and review all SMS/OTP events during exposure window.
Call-screening/default phone role	Enables call blocking and fraud-call suppression.	Restore default phone app; review missed/rejected calls from banks and fraud teams.
Notification access	Allows notification reading and possible data capture from messaging/banking apps.	Remove access and rotate credentials exposed through notifications.
Modify system settings / DND / audio controls	Allows muting, brightness changes, and interruption suppression.	Reset notification/DND/sound policies; inspect for user-visible suppression.
Google Play Protect disablement	Command set includes Play Protect disablement behavior.	Re-enable Play Protect; verify Play Services integrity and device compliance.
Local SQLite overlay store	Fake HTML banking pages may be cached locally.	Preserve forensic image before wipe if investigation requires evidence.

Persistence should be treated as a reason to distrust the device state. If the infected phone was enrolled in an enterprise MDM, revoke tokens, remove trusted-device status, wipe/re-enroll, and validate that the malicious app and all granted roles are gone before restoring access.

10. Network and Infrastructure Analysis

Zimperium reports HTTPS C2 communication and dynamic C2 failover. The malware initially sends basic device telemetry and then exchanges command/configuration data with its server. A captured configuration update included multiple fallback domains.

Indicator	Type	Source/context	Recommended handling
`infocontablidades.it.com`	Distribution domain	Zimperium described malicious website used for delivery.	Block and hunt DNS/proxy/mobile-browser access.
`beralisvc.info`	C2 fallback domain	Present in Zimperium `update_config_domen` example.	Block and hunt; inspect HTTPS connections around install times.
`blestorians.cfd`	C2 fallback domain	Present in Zimperium `update_config_domen` example.	Block and hunt; look for same device contacting multiple fallback domains.
`abiorime.cfd`	C2 fallback domain	Present in Zimperium `update_config_domen` example.	Block and hunt.
`morevoms.cfd`	C2 fallback domain	Present in Zimperium	Block and hunt.

		`update_config_domen` example.	
`monitored_app_full`	Endpoint/path token	Target-app list retrieval described by Zimperium.	Hunt in proxy/body logs where available; useful in static rules.
`get_html_mapping`, `save_apps`	Endpoint/path tokens	Installed-app inventory and overlay mapping interactions described by Zimperium.	Hunt in mobile proxy logs if TLS inspection or app telemetry is available.
`update_config_domen`	Command/config token	Dynamic C2 domain update.	Hunt in static strings and command telemetry if MTD exposes app content.

Infrastructure notes:

- Do not assume the five listed domains are exhaustive. The family supports fallback and dynamic domain updates.
- The use of commodity TLDs and HTTPS means network controls need device context, domain reputation, and behavioral correlation rather than domain lists alone.
- For managed mobile fleets, combine DNS/proxy hits with MDM events such as sideloaded APK install, Accessibility grant, and SMS role change to reduce false positives.

11. Indicators of Compromise

Type	Indicator	Notes
Malware family	Rokarolla	Android banking trojan named after C2 infrastructure in Zimperium reporting.
Delivery domain	`infocontabilidades.it.com`	Defang as `hxxps[://]infocontabilidades[.lit[.]com/` when sharing externally.
C2 domain	`beralisvc.info`	From Zimperium C2 config example.
C2 domain	`blestorians.cfd`	From Zimperium C2 config example.
C2 domain	`abiorime.cfd`	From Zimperium C2 config example.
C2 domain	`morevoms.cfd`	From Zimperium C2 config example.
Behavior	Accessibility Service enabled for unknown app	High-signal behavioral IOC.
Behavior	Unknown app becomes default SMS handler	High-signal behavioral IOC.
Behavior	Unknown app obtains call-screening role	High-signal behavioral IOC.
Behavior	Google Play Protect disabled after sideloaded install	High-signal behavioral IOC.
Behavior	Clipboard content changes immediately after copying crypto address	User-observable fraud behavior; collect wallet transaction details.
Behavior	Banking/crypto login page appears as overlay after opening legitimate app	User-observable fraud behavior; preserve screenshots if safe.

The 40 SHA-256 hashes listed in Section 5 should be loaded into mobile-threat-defense, malware-analysis, SOAR enrichment, and SIEM watchlists. Where tooling supports it, tag them as `malware-family:Rokarolla`, `platform:Android`, `type:banker`, and `source:Zimperium IOC 2026-06-Rokarolla`.

12. MITRE ATT&CK Mapping

Technique	Name	Rokarolla behavior	Confidence
T1476	Deliver Malicious App via Other Means	Malicious websites distribute fake popular/security apps outside trusted install flows.	High
T1406	Obfuscated Files or Information	Banker samples likely package configuration/overlay logic within APKs; exact obfuscation not independently verified here.	Medium
T1626	Abuse Elevation Control Mechanism	Social-engineers Accessibility and Android role grants to gain control capabilities.	High
T1411	Input Capture	Keylogger and UI logger capture typed input and screen text.	High
T1517	Access Notifications	Requests notification access and can read notification content.	High
T1412	Capture SMS Messages	Reads SMS to capture OTPs and sensitive messages.	High
T1660	Phishing	HTML overlays mimic banking/crypto login pages and Android lock screens.	High
T1417	Input Injection	Uses Accessibility to tap, swipe, click UI elements, and automate settings changes.	High
T1429	Audio Capture / device sensor abuse adjacent	Public reporting emphasizes disabling sounds rather than recording audio; map only if sample-specific evidence shows capture.	Low
T1420	File and Directory Discovery	All-files access and app inventory behaviors can expose local data; exact file theft scope requires sample validation.	Medium
T1430	Location Tracking	Not reported as a primary capability in public sources; do not assume without sample evidence.	Low
T1616	Call Control	Call blocking and call-screening role abuse suppress	High

		fraud-warning calls.	
T1638	Adversary-in-the-Middle / clipboard manipulation adjacent	Clipboard replacement redirects cryptocurrency payments; ATT&CK mapping may vary by matrix version.	Medium
T1521	Encrypted Channel	HTTPS C2 communications.	High
T1525	Implant Internal Image Capture	Screen capture through Accessibility screenshot-like workflow instead of MediaProjection.	Medium-High

13. Detection Engineering

Detection should combine four layers: known IOCs, risky Android permission/role changes, suspicious install source, and financial-fraud behavior. The highest-value alert is not a single domain hit; it is the combination of sideloaded APK + Accessibility grant + SMS/call role change + rare-domain HTTPS.

Detection objective	Data source	Logic	Priority
Known Rokarolla APK installed	MDM / MTD / app inventory	SHA-256 equals Zimperium IOC hash list.	Critical
Dangerous role change after sideload	MDM / Android Enterprise / MTD	Non-approved app granted Accessibility, default SMS, call screening, notification access, or modify settings within 24h of install.	Critical
Known infrastructure access	DNS/proxy/mobile secure web gateway	Device connects to listed domains or URLs containing C2 path tokens.	High
Banking overlay behavior	MTD / accessibility/overlay telemetry	Unknown app uses overlay while banking/crypto package is foreground.	Critical
OTP interception risk	MDM/MTD + IAM/banking logs	SMS handler change followed by suspicious login, trusted-device add, or high-risk transfer.	Critical
Crypto clipboard theft	EDR/MTD where available or user report	Clipboard write by unknown app after wallet address copy.	High

Example Sigma-style rule for MDM or mobile-threat-defense events:

```

title: Android Unknown App Gains Accessibility and SMS or Call Control
id: 64ec5831-0f43-4ef2-9b7b-rokarolla-accessibility-role-abuse
status: experimental
description: Detects a suspicious Android application receiving Accessibility access and SMS/call control privileges, a pattern consistent with Rokarolla-style banking trojans.
author: Lost Boys Cyber
date: 2026/06/16
references:
  - https://zimperium.com/blog/rokarolla-android-banker-with-complete-device-takeover-capabilities
  - https://github.com/Zimperium/IOC/tree/master/2026-06-Rokarolla

```

```

logsource:
  product: android
  service: mdm
selection_accessibility:
  event.action|contains:
    - accessibility_service_enabled
    - accessibility_permission_granted
selection_role:
  event.action|contains:
    - default_sms_app_changed
    - call_screening_role_granted
    - notification_listener_enabled
    - modify_system_settings_granted
filter_approved:
  app.package.name:
    - com.google.android.apps.messaging
    - com.google.android.dialer
    - com.android.dialer
condition: selection_accessibility and selection_role and not filter_approved
fields:
  - device.id
  - user.name
  - app.package.name
  - app.label
  - app.sha256
  - event.action
  - event.time
level: critical

```

Example Microsoft Defender XDR / Intune-oriented KQL. Field names vary by tenant; tune table names to your MDM connector schema.

```

let RokarollaDomains = dynamic([
  "infocontablidades.it.com",
  "beralisvc.info",
  "blestorians.cfd",
  "abiorime.cfd",
  "morevoms.cfd"
]);
let RokarollaHashes = dynamic([
  "890ecea4ebe4fea692ad36adf02abeb37c181cb7bdb6122cd52d9aaafe7d6cf3",
  "7aa389f25997610a96f014977eecd6d69142bdc63841e0d84976e3e621831303",
  "4e2cbefc6bdbfdb6e885057ce47d460e3d3355a5e97db51b22e9c5a14e14302b",
  "1ba364113c4cec5542d1b2c76d7c163a66bdf90bc373256d5178f880f9742960",
  "d7d960ef10b08c472ad397b6fd9e9481338b2077c7c2f44d3dc2c65b19345ae0"
]);
let SuspiciousMobileApps =
DeviceTvmSoftwareInventory
| where OSPlatform has "Android"
| where SHA256 in (RokarollaHashes) or SoftwareName has_any ("Play Protect", "TikTok", "Chrome")
| project DeviceId, DeviceName, UserName, SoftwareName, SoftwareVendor, SHA256,
AppInstallTime=Timestamp;
let SuspiciousNetwork =
DeviceNetworkEvents
| where RemoteUrl has_any (RokarollaDomains) or RemoteUrl has_any ("monitored_app_full",
"get_html_mapping", "save_apps", "update_config_domen")
| project DeviceId, NetTime=Timestamp, RemoteUrl, RemoteIP, InitiatingProcessAccountName;
SuspiciousMobileApps
| join kind=leftouter SuspiciousNetwork on DeviceId
| where isnull(NetTime) or NetTime between (AppInstallTime - 1d .. AppInstallTime + 7d)
| project DeviceName, UserName, SoftwareName, SHA256, AppInstallTime, RemoteUrl, RemoteIP, NetTime
| order by AppInstallTime desc

```

Example Splunk query for mobile proxy, DNS, or secure web gateway logs:

```

(index=proxy OR index=dns OR index=mobile_security)
(domain IN

```

```
(
  "infocontabilidades.it.com", "beralisvc.info", "blestorians.cfd", "abiorime.cfd", "morevoms.cfd")
  OR url="*monitored_app_full*" OR url="*get_html_mapping*" OR url="*save_apps*" OR
url="*update_config_domen*")
| stats earliest(_time) as first_seen latest(_time) as last_seen values(url) as urls values(domain) as
domains values(app) as apps by user device src_ip
| convert ctime(first_seen) ctime(last_seen)
| lookup mobile_device_inventory device OUTPUT os_platform managed_status owner app_install_source
| where os_platform="Android" OR like(os_platform, "%Android%")
| sort -last_seen
```

Example YARA rule for triage of unpacked APK contents or string extracts. This is a heuristic, not a family-proof signature.

```
rule Android_Banker_Rokarolla_Command_Strings_Heuristic
{
  meta:
    author = "Lost Boys Cyber"
    date = "2026-06-16"
    description = "Heuristic string rule for Rokarolla-like Android banker command/config strings"
    source = "Zimperium zLabs public Rokarolla research and IOC command list"
    confidence = "medium"
  strings:
    $cmd1 = "update_config_domen" ascii wide
    $cmd2 = "monitored_app_full" ascii wide
    $cmd3 = "get_html_mapping" ascii wide
    $cmd4 = "save_apps" ascii wide
    $cmd5 = "request_pin" ascii wide
    $cmd6 = "request_pattern" ascii wide
    $cmd7 = "start_keylogger" ascii wide
    $cmd8 = "copyclipboard" ascii wide
    $cmd9 = "disable_google_play" ascii wide
    $cmd10 = "calls_block" ascii wide
    $dom1 = "beralisvc.info" ascii wide
    $dom2 = "blestorians.cfd" ascii wide
    $dom3 = "abiorime.cfd" ascii wide
    $dom4 = "morevoms.cfd" ascii wide
  condition:
    uint32(0) == 0x04034b50 and
    (4 of ($cmd*) or (2 of ($cmd*) and 1 of ($dom*)))
}
```

14. Threat Hunting

Threat hunting should focus on users and devices with financial access, executives, finance teams, crypto-wallet users, help-desk staff with reset authority, and BYOD Android endpoints.

Hunt hypothesis	Data required	Expected signal
A user installed a fake security/popular app and then granted dangerous Android roles.	MDM/MTD install and permission events.	Sideloaded app followed by Accessibility, SMS, call-screening, notification, or DND grant.
Rokarolla C2 was contacted from a mobile device.	DNS/proxy/SWG/mobile VPN logs.	Connections to listed domains or C2 path tokens from Android user agents.
A banking login or crypto transfer occurred after mobile compromise.	IAM, banking, fraud, exchange, and device posture logs.	High-risk transaction within exposure window of mobile IOC hit.
User warnings were suppressed.	Call logs, MDM device state, DND/sound settings.	Missed/rejected bank fraud calls, DND enabled, volume muted, brightness low after app install.
OTP interception was used.	SMS logs where legally/contractually available, IAM MFA logs, banking audit.	SMS OTP delivered to compromised device followed by login/transfer from new

		device/session.
--	--	-----------------

Generic MDM hunt for risky Android permission chains:

```
let RiskyActions = dynamic([
  "accessibility_service_enabled",
  "notification_listener_enabled",
  "default_sms_app_changed",
  "call_screening_role_granted",
  "modify_system_settings_granted",
  "do_not_disturb_access_granted",
  "install_from_unknown_source"
]);
MobileDeviceEvents
| where OSPlatform == "Android"
| where ActionType in (RiskyActions)
| summarize Actions=make_set(ActionType), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Apps=make_set(AppName), Packages=make_set(PackageName) by DeviceId, DeviceName, UserPrincipalName,
bin(Timestamp, 1d)
| where set_has_element(Actions, "accessibility_service_enabled")
| where array_length(Actions) >= 3
| project FirstSeen, LastSeen, DeviceName, UserPrincipalName, Actions, Apps, Packages
| order by LastSeen desc
```

DNS/proxy hunt for Rokarolla infrastructure and suspicious banker endpoints:

```
(index=dns OR index=proxy OR index=swg)
("infocontablidades.it.com" OR "beralisvc.info" OR "blestorians.cfd" OR "abiorime.cfd" OR
"morevoms.cfd" OR "monitored_app_full" OR "get_html_mapping" OR "save_apps" OR "update_config_domen")
| eval rokarolla_signal=case(
  match(_raw,"infocontablidades\.it\.com"),"delivery_domain",
  match(_raw,"beralisvc\.info|blestorians\.cfd|abiorime\.cfd|morevoms\.cfd"),"c2_domain",
  match(_raw,"monitored_app_full|get_html_mapping|save_apps|update_config_domen"),"c2_path_token",
  true(),"other")
| stats count values(rokarolla_signal) as signals values(url) as urls values(http_user_agent) as
user_agents by user src_ip device
| sort -count
```

IAM/fraud correlation hunt:

```
let MobileRiskWindow =
MobileDeviceEvents
| where OSPlatform == "Android"
| where ActionType in ("accessibility_service_enabled", "default_sms_app_changed",
"call_screening_role_granted")
| summarize FirstRisk=min(Timestamp), LastRisk=max(Timestamp), RiskActions=make_set(ActionType) by
UserPrincipalName, DeviceId;
let HighRiskAuth =
SigninLogs
| where ResultType == 0
| where RiskLevelDuringSignIn in ("medium", "high") or AuthenticationRequirement has
"multiFactorAuthentication"
| project UserPrincipalName, SigninTime=TimeGenerated, IPAddress, AppDisplayName,
ConditionalAccessStatus, RiskLevelDuringSignIn;
MobileRiskWindow
| join kind=inner HighRiskAuth on UserPrincipalName
| where SigninTime between (FirstRisk - 1d .. LastRisk + 7d)
| project UserPrincipalName, DeviceId, RiskActions, FirstRisk, LastRisk, SigninTime, IPAddress,
AppDisplayName, RiskLevelDuringSignIn, ConditionalAccessStatus
| order by SigninTime desc
```

15. Triage and Incident Response

Treat a Rokarolla alert as a mobile-account-takeover incident. The response goal is to contain the device, preserve enough evidence for fraud review, and revoke all trust derived from the compromised phone.

Priority	Action	Owner	Notes
----------	--------	-------	-------

P0	Remove the device from corporate access and block mobile sessions.	IAM / MDM	Revoke tokens, trusted-device status, and mobile VPN sessions.
P0	Contact affected user out-of-band.	SOC / Help Desk	Do not rely only on calls/SMS to the suspected device because Rokarolla can block calls and read SMS.
P0	Notify banking/crypto providers and freeze high-risk transactions where applicable.	Fraud / Finance / Legal	Include suspected infection window and OTP exposure risk.
P1	Preserve forensic artifacts if required.	DFIR	Collect app inventory, installed APK, granted permissions, package metadata, network logs, screenshots, and MDM timeline before wipe.
P1	Factory reset or reimage/re-enroll the device.	MDM / User Support	Simple uninstall may not be enough for confidence after credential theft.
P1	Rotate exposed credentials and invalidate sessions.	IAM / App Owners	Include passwords typed on phone, banking passwords, exchange credentials, messaging sessions, and recovery codes viewed on device.
P1	Review SMS OTP and call history.	Fraud / User Support	Look for bank calls blocked or OTPs received before suspicious transactions.
P2	Hunt peer devices and users.	SOC	Pivot on IOCs, risky Android role chains, and same distribution source.

Recommended evidence collection checklist:

- Device identifier, user, enrollment state, ownership model, OS version, patch level.
- Full installed-application inventory, including package names, labels, versions, signing certificate details, install source, install time, and SHA-256 where available.
- Accessibility, notification listener, default SMS, call-screening, DND, modify-system-settings, and all-files-access permission state.
- DNS/proxy/SWG/mobile VPN logs for listed domains and unusual HTTPS destinations.
- Authentication logs, MFA events, trusted-device additions, password resets, and recovery-code access.
- Banking/crypto account access and transaction records for the likely infection window.

16. Validation and Emulation

Because no live sample was executed by Lost Boys Cyber in this task, validation should be performed in a controlled Android malware lab before converting heuristics into production-blocking controls. Recommended validation path:

Validation item	Method	Success criteria
-----------------	--------	------------------

IOC ingestion	Load 40 SHA-256 hashes into MTD/SIEM test watchlist.	Test event containing one hash triggers expected severity and enrichment.
Domain detection	Replay DNS/proxy test events for listed domains.	SIEM alerts include device/user context and recommended containment.
Permission-chain detection	Generate synthetic MDM events for Accessibility + SMS role + call role.	Correlation fires only when risky chain occurs for non-approved app.
YARA heuristic	Run against unpacked benign APKs and any acquired Rokarolla sample.	Low false-positive rate on benign APK set; positive on sample/string corpus.
Incident playbook	Tabletop with SOC, help desk, finance, and IAM.	Team can contact user out-of-band, revoke access, and freeze financial exposure quickly.

Safe emulation ideas for defenders:

- Use an internal benign Android test app or MDM test harness to generate Accessibility grant, notification listener, SMS role, and call-screening role events without collecting user data.
- Replay known Rokarolla domain indicators into DNS/proxy logs from a lab source IP; do not browse live malware distribution sites from production networks.
- Simulate suspicious account activity following a mobile-risk event to validate fraud/IAM correlation logic.
- If a real APK sample is acquired, detonate only inside an isolated Android lab with controlled network sinkhole and no personal accounts, SIM, wallet, or real banking apps.

17. Recommendations

Priority	Recommendation	Rationale
Critical	Prohibit or tightly control Android sideloading for managed devices.	Rokarolla's reported delivery path depends on convincing users to install APKs from malicious websites.
Critical	Alert on Accessibility grants to non-approved apps.	Accessibility abuse is central to overlays, remote clicks, screen/UI extraction, and permission automation.
Critical	Alert on unknown apps becoming default SMS handler, call-screening provider, or notification listener.	These roles enable OTP theft, call suppression, and notification harvesting.
High	Require phishing-resistant MFA for financial and administrative workflows.	SMS OTP is directly exposed by Rokarolla-style malware.
High	Add C2/distribution domains and APK hashes to MTD, SIEM, proxy, and SOAR enrichment.	Public IOCs provide immediate known-bad coverage.
High	Correlate mobile posture with high-risk banking, IAM, and crypto transactions.	Mobile compromise can explain otherwise valid credentials and MFA use.
High	Educate users that Google Play Protect is not installed from random websites and that Accessibility requests from new apps are dangerous.	User approval is the main initial access and escalation path.
Medium	Monitor clipboard-abuse reports for	Clipboard replacement can redirect wallet

	cryptocurrency users.	payments without credential theft.
Medium	Maintain an Android malware lab for validation.	Production detections require sample-safe validation and false-positive tuning.
Medium	Review BYOD policy for finance/executive users.	Personal Android devices accessing corporate or financial systems increase exposure.

Implementation sequence for a small SOC:

- 1. Load hash/domain IOCs and create a Rokarolla tag in enrichment tooling.
- 2. Deploy permission-chain detections for Android Accessibility + SMS/call/notification role changes.
- 3. Add an incident-response checklist for mobile account takeover with out-of-band user contact.
- 4. Coordinate with finance/fraud stakeholders on transaction freeze and review triggers.
- 5. Run a 30-day retro-hunt across DNS/proxy/MDM logs for listed indicators and risky role chains.
- 6. Test detections quarterly against synthetic MDM events and updated mobile banker intelligence.

18. References and Refresh Notes

- [1] Zimperium zLabs. "Rokarolla: Android Banker with Complete Device Takeover Capabilities." <https://zimperium.com/blog/rokarolla-android-banker-with-complete-device-takeover-capabilities>
- [2] Zimperium IOC repository. `2026-06-Rokarolla` indicators and command reference. <https://github.com/Zimperium/IOC/tree/master/2026-06-Rokarolla>
- [3] The Hacker News. "New Rokarolla Android Malware Steals PINs, SMS Codes, and Crypto Wallet Funds." <https://thehackernews.com/2026/06/new-rokarolla-android-malware-steals.html>
- [4] MITRE ATT&CK for Mobile. Mobile tactics and techniques reference. <https://attack.mitre.org/matrices/mobile/>

Refresh guidance:

- Re-check the Zimperium IOC repository before publication or operational loading; public mobile malware IOC sets often receive additions after first publication.
- If a live APK sample becomes available, update Sections 5-7 with manifest permissions, package names, certificate metadata, strings, decompiled functions, configuration extraction, sandbox network traces, dropped files, and exact process/component names.
- If customer telemetry identifies infections, append a victim-environment section with observed install source, user impact, transaction impact, containment actions, and confirmed data exposure.
- Revalidate MITRE mappings against the current ATT&CK for Mobile matrix during final QA because technique IDs and names can change across ATT&CK versions.